Security+ Acronym Study Guide

Written By: Raza Tahir

This document provides definitions and explanations of acronyms relevant to the CompTIA Security+ SY0-701 exam as shown on the official guide. It is intended to support exam preparation by helping candidates understand and review key terminology.

A

AAA (Authentication, Authorization, and Accounting): A security framework for verifying identities, granting permissions, and recording resource usage.

ACL (Access Control List): A table that specifies which users or groups can access a resource (e.g., a file) and their permitted actions.

[Link](https://firewalltimes.com/access-control-list/)

[Link](https://learn.microsoft.com/en-us/windows/win32/secauthz/access-control-lists)

AES (Advanced Encryption Standard): A widely adopted symmetric encryption algorithm that protects data with a single key used for both encryption and decryption.

Helpful Video: https://www.youtube.com/watch?v=C4ATDMIz5wc

AES-256: A type of AES encryption using a 256-bit key for strong protection against brute-force attacks.

AH (Authentication Header): A component of the IPsec protocol that authenticates packet origins and integrity without encrypting payloads.

AI (Artificial Intelligence): The technology that enables machines to perform tasks with humanlike intelligence, reasoning and learning.

AIS (Automated Indicator Sharing): A system for sharing cyber threat indicators between public and private sectors, and acts like a neighborhood watch for computers. In maritime operations, if a ship's transponder fails, its last known location freezes or disappears from other vessels' electronic charts.

ALE (Annualized Loss Expectancy): expected financial loss from a specific risk in one year.

> **Formula:**
>
> ALE = Cost per incident (SLE, Single Loss Expectancy) × Expected number of incidents per year (ARO, Annualized Rate of Occurrence)

AP ([Wireless] Access Point): A hardware device that provides wireless connectivity to clients.

> Example: When my phone provides a hotspot for my laptop, it acts as a **Wireless Access Point (AP)** that allows my laptop to connect to the internet through the phone.

API (Application Programming Interface): A set of functions and rules that allow two software applications to communicate with each other.

APT (Advanced Persistent Threat): A long-term, targeted cyberattack designed to infiltrate an organization's network and remain undetected for as long as possible.

[Link] (https://www.microsoft.com/en-us/security/business/security-101/what-is-advanced-persistent-threat-apt)

ARO (Annualized Rate of Occurrence): The estimated number of times a risk is expected to happen in one year.

ARP (Address Resolution Protocol): A communication network protocol that maps IPv4 addresses to an MAC address on a local network.

ASLR (Address Space Layout Randomization): A computer security technique that randomizes memory locations every time it runs so that hackers can't exploit memory vulnerabilities.

ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge): A knowledge base maintained by MITRE for listing and explaining adversary tactics and techniques from observed cyberattacks.

AUP (Acceptable Use Policy): A document that explains the rules and permissions people must follow when using an organization's technology and information systems.

Example: https://workspace.google.com/terms/use_policy/

AV (Antivirus): Software that identifies, blocks, and removes malicious programs.

B

BASH (Bourne Again Shell): A free, open-source Unix shell and command-language interpreter for interactive use and scripting. Bash lets users type commands to control their computer and write scripts to automate tasks. Bash is commonly used on Linux and macOS, and it is also available on Windows through tools such as Git Bash!

BCP (Business Continuity Planning): A broad, organization-wide strategy that provides teams with a clear action plan to maintain essential operations, recover from disruptions, and minimize the impact of unexpected incidents. Unlike a Disaster Recovery Plan (DRP), which focuses primarily on restoring IT systems, infrastructure, and data, a BCP addresses how to keep the entire business operating during a crisis, including staffing, physical facilities, communications, vendors, and customer service.

[Source] https://www.datto.com/blog/what-is-a-business-continuity-plan/

BGP (Border Gateway Protocol): The protocol used to exchange routing information between autonomous systems across the internet.

BIA (Business Impact Analysis): A proactive process conducted before a disruption to identify and evaluate how potential disruptions (whether natural or man-made) affect critical business functions and establishes recovery priorities that helps the business decide what to recover first and what resources are needed. It also sets time limits, such as how quickly systems must be restored (RTO), how much data loss can be tolerated (RPO), and the maximum downtime the business can tolerate (MTD), helping it determine what to fix first during a crisis.

BIOS (Basic Input/Output System): Firmware used to initialize hardware and start the operating system during boot. It checks hardware components (CPU, RAM, storage, keyboard) for errors.

BPA (Business Partners Agreement): Think: **Big Picture Partnership.**

A foundational contract that establishes the formal terms of a business collaboration, defining governance, rights, obligations, and the allocation of resources and risk. By comparison, while a Memorandum of Understanding (MOU) typically signals a mutual intent to cooperate, and a Memorandum of Agreement (MOA) often outlines specific operational commitments, the legal binding power of any such document ultimately depends on its specific language, the applicable law and mutual intent rather than its title alone.

For example:

- **BPA:** They agree on how to share profits, expenses, and business risks.
- **MOA:** They agree that Company A develops the software by June, while Company B tests it by July.

[Read More](https://www.adobe.com/acrobat/business/resources/business-partnership-agreement.html)

BPDU (Bridge Protocol Data Unit): A type of switch message that is transmitted by a local area network (LAN) bridge.

BYOD (Bring Your Own Device): A policy model that allows employees to use their personal devices for work, allowing access to company systems under established security rules.

- **BYOD** (Bring Your Own Device) is a separate mobile device management approach from **CYOD** (Choose Your Own Device) and **COPE** (Corporate-Owned, Personally Enabled).

Link: https://www.comptia.org/en-us/blog/corporate-acceptable-use-policy-a-key-part-of-security-awareness-training/

C

CA (Certificate Authority): A trusted entity that issues and validates digital certificates.

CAPTCHA: A type of challenge designed to distinguish human users from automated programs.

CAR (Corrective Action Report): A Quality Management report that documents the problem, its root cause, the corrective actions required to resolve it, and the completion status.

CASB (Cloud Access Security Broker): A security policy that enforces security policies between users and cloud services.

Link: https://www.microsoft.com/en-us/security/business/security-101/what-is-a-cloud-access-security-broker-casb

CBC (Cipher Block Chaining): A mode of operation for a block cipher; it provides a method of encrypting data (whether read from a database or captured from a network) by dividing data into fixed-size blocks in memory. It then applies a mixing process: the first block is combined with an initialization vector (IV), and each subsequent block is mixed with the previous ciphertext block before encryption. This hides underlying patterns, and the final encrypted result is either saved to disk or sent across the network. This method provides confidentiality but not message integrity.

CCMP (Counter Mode/CBC-MAC Protocol): A Wi-Fi security protocol combining AES counter-mode encryption with integrity protection.

CCTV (Closed-Circuit Television): A private video surveillance system used for monitoring and surveillance.

CERT (Computer Emergency Response/Readiness Team): A broad cybersecurity response and coordination team.

CFB (Cipher Feedback): A mode of operation for a block cipher; this produces stream-like encryption through feedback from prior ciphertext.

CHAP: A type of security authentication protocol that authenticates clients (verifies their identity) through challenge-response exchanges without transmitting their actual passwords over the network.

CIA Triad: A security model prioritizing confidentiality, integrity, and availability.

CIO (Chief Information Officer): An executive overseeing information technology strategy and alignment with organizational goals.

CIRT (Computer Incident Response Team): An internal response team that investigates, contains, and recovers from computer security incidents.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-incident-response)

CMS (Content Management System): Software that simplifies website content creation, organization, and publishing. E.g. WordPress, Squarespace.

COOP (Continuity of Operations Planning): A process by government agencies to ensure essential government functions continue throughout emergencies.

COPE (Corporate Owned, Personally Enabled): A policy model in which an organization provides an employee with a company-owned device for work and limited personal use.

CP (Contingency Planning): A plan that defines responses for significant events that could disrupt operations. Think: Batman.

CRC (Cyclic Redundancy Check): Code that detects accidental data corruption during storage or transmission.

CRL (Certificate Revocation List): A digitally signed file published by a Certificate Authority (CA) that lists the serial numbers of digital certificates revoked before their scheduled expiration dates.

Link: https://securew2.com/blog/certificate-revocation-crl-explained

CSO (Chief Security Officer): An executive responsible for protecting organizational people, information, and physical assets.

CSP (Cloud Service Provider): Vendor delivering cloud-based infrastructure, platforms, or software services. The big 3 are AWS, Azure & Google Cloud Platform (GCP).

CSR (Certificate Signing Request): An encoded message request (sent from an applicant) that contains information needed by a CA to issue a certificate.

CSRF (Cross-Site Request Forgery): A type of malicious exploit in which a website tricks authenticated browsers into submitting unauthorized requests to trusted applications

Example:

1. Alice logs into her bank. The bank stores an authentication cookie in her browser.
2. On the same window, Alice opens a new tab and visits a malicious website.

3. The malicious website tricks her browser into sending a request to her bank and may automatically attach the bank's authentication cookie to that request.
4. If the bank lacks proper CSRF protection, it might accept the unauthorized request.

CSU (Channel Service Unit): A device that connects digital terminal equipment to a telecommunications circuit.

CTM (Counter Mode): A mode of operation that encrypts data using a block cipher, but it works like a stream cipher.

CTO (Chief Technology Officer): An executive directing technological strategy, development, and innovation.

CVE (Common Vulnerability Enumeration a.k.a. Common Vulnerabilities and Exposures): A serial number tagged for a specific security flaw/weakness.

> Example:
>
> **CVE-2017-5638** identifies a critical vulnerability in the Apache Struts 2 web application framework that was exploited in the 2017 Equifax data breach.

CVSS (Common Vulnerability Scoring System): A framework for rating the severity of software vulnerabilities [Link](https://www.first.org/cvss/)

CYOD (Choose Your Own Device): A policy model that lets employees select work devices from an approved organizational list.

D

DAC (Discretionary Access Control): An access control model in which a resource owner, subject to the system's security policies, has the authority to grant, modify, or revoke other users' access permissions to that resource. These permissions can be implemented using Access Control Lists (ACLs). It is widely recognized as one of the core access control models (alongside MAC and RBAC).

> Example:
>
> On a Windows computer, right-click a file, selecting Properties → Security, and changing its access permissions is an example of Discretionary Access Control (DAC).

DBA (Database Administrator): A specialist maintaining database availability, security, performance, and integrity.

DDoS (Distributed Denial-of-Service): A type of cyberattack in which many compromised systems overwhelm a targets server and cause a denial of service that prevents legitimate users from accessing the targeted resource, often resulting in unresponsive services or slow response times.

> TL;DR: This attack floods a server with bot traffic to disrupt availability.

[Link: https://www.splunk.com/en_us/blog/learn/ddos-attacks.html]

DEP (Data Execution Prevention): A security feature in an OS that blocks code execution in protected memory regions to reduce exploitation.

[Link](https://learn.microsoft.com/en-us/windows/win32/memory/data-execution-prevention)

DES (Data Encryption Standard): An obsolete symmetric block cipher that encrypts data in 64-bit blocks using a 56-bit secret key. It is considered insecure because its short key length makes it vulnerable to brute-force attacks that use modern computing power.

[Link](https://www.nist.gov/blogs/cybersecurity-insights/cornerstone-cybersecurity-cryptographic-standards-and-50-year-evolution)

DHCP (Dynamic Host Configuration Protocol): A network protocol that automatically assigns IP addresses and network configuration settings to devices on a network.

DHE (Diffie-Hellman Ephemeral): A key-agreement method that allows two parties to establish a shared secret over an insecure channel using temporary key pairs. Each party exchanges a public key share and independently computes the same shared secret, which can be used to derive session keys.

https://www.youtube.com/watch?v=85oMrKd8afY

DKIM (DomainKeys Identified Mail): An email security standard that uses digital signatures to verify email domain authenticity and message integrity.

DLL (Dynamic Link Library): A library file stored on a computer that provides reusable code and functions to multiple software programs. Windows OS primarily uses the '.dll' extension for DLL files, alongside related extensions like .ocx, .drv, and .sys.

> Example:
>
> **Windows Media Player** is a default application on a Windows computer that uses **winmm.dll**. This shared Windows library can be used by multiple programs (e.g. music or game software) to access multimedia functionality.

[Link](https://learn.microsoft.com/en-us/troubleshoot/windows-client/setup-upgrade-and-drivers/dynamic-link-library)

[Link](https://www.lenovo.com/us/en/glossary/dynamic-link-library/)

DLP (Data Loss Prevention): A system (i.e. a set of technologies and processes) that identifies and prevents unauthorized access, leaks or disclosure of sensitive information by monitoring and controlling data transfers.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-data-loss-prevention-dlp)

DMARC (Domain Message Authentication Reporting and Conformance): An email authentication protocol to protect email domains from email domain spoofing by checking SPF and DKIM results.

DNAT (Destination Network Address Translation): A technique that changes packet destination addresses, commonly forwarding traffic to internal hosts.

DNS (Domain Name System): A naming system that translates domain names into IP addresses and other resource records. By default, Port 53 is the default port for DNS.

DoS (Denial-of-Service): A type of cyberattack that disrupts a system or service for legitimate users by flooding or overwhelming a host connected to the internet from a single source or device.

DPO (Data Protection Officer): An executive that oversees privacy compliance and organizational protection of personal data.

DRP (Disaster Recovery Plan): A plan that offers procedures for recovering vital systems and data following disruption.

DSA (Digital Signature Algorithm): An asymmetric cryptographic algorithm that is standard for creating and verifying digital signatures. It uses a private key to sign, and a public key to verify. Examples can include RSA and ECDSA.

DSL (Digital Subscriber Line): A broadband internet technology that provides internet through existing telephone wiring. Talking on a landline phone can affect a DSL internet connection.

E

EAP (Extensible Authentication Protocol): An authentication framework that supports multiple methods for network access e.g. wireless networks and Point-to-Point connections.

[Link](https://learn.microsoft.com/en-us/windows-server/networking/technologies/extensible-authentication-protocol/network-access?tabs=eap-tls%2Cserveruserprompt-eap-tls%2Ceap-sim)

ECB (Electronic Codebook): A mode of operation for a block cipher that encrypts plaintext blocks into corresponding ciphertext blocks.

ECC (Elliptic Curve Cryptography): An approach to the asymmetric public-key cryptography system that is based on the algebraic structure of elliptic curves over finite fields. It offers strong security with comparatively small keys and can be used for encryption, key exchanges (e.g. ECDH), and digital signatures (e.g. ECDSA or EdDSA).

ECDHE: A variant of the Diffie-Hellman algorithm that uses elliptic-curve key exchange using temporary keys to provide forward secrecy.

ECDSA (Elliptic Curve Digital Signature Algorithm): A cryptographic public-key algorithm that is used for generating and verifying digital signatures.

> Example:
>
> Bitcoin relies on the ECDSA as its foundational cryptographic system to prove ownership and authorize transactions

EDR (Endpoint Detection and Response): A cybersecurity technology that continuously monitors endpoints to detect, investigate, and respond to threats. EDR can work with SIEM to centralize threat log data, SOAR to automate response actions, and IAM to connect endpoint activity with user identities and access permissions.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-edr-endpoint-detection-response)

EFS (Encrypting File System): A built-in Windows feature that encrypts files and folders on NTFS volumes.

ERP (Enterprise Resource Planning): “A software system that helps organizations streamline their core business processes—including finance, HR, manufacturing, supply chain, sales, and procurement—with a unified view of activity and provides a single source of truth.”
(SAP, 2026, [Link](https://www.sap.com/resources/what-is-erp))

ESN (Electronic Serial Number): A unique identification number that’s assigned by manufacturers to certain cellular devices.

ESP (Encapsulating Security Payload): A component of IPsec protocol that provides confidentiality, along with some authentication and integrity to data.

F

FACL (File System Access Control List): A type of ACL (Access Control List) that defines user and group permissions for files and directories.

FDE (Full-Disk Encryption): A method of encryption that converts entire storage drives data into unreadable ciphertext. The data remains locked and scrambled even when powered off.

FIM (File Integrity Monitoring/Management): A technology that detects and reports unauthorized or unexpected file changes.

> Example:
>
> https://learn.microsoft.com/en-us/azure/defender-for-cloud/file-integrity-monitoring-overview

FPGA (Field-Programmable Gate Array): A chip that contains configurable digital circuits that are configurable after manufacturing for specialized processing tasks by a customer.

> Example:
>
> Emulation developers can program an FPGA chip to replicate the hardware of different gaming consoles, such as Sega systems and the Nintendo 64. The FPGA can then be integrated into a physical FPGA-based gaming system, with a compatible board providing the supporting components and interfaces (e.g. sound, memory, controller, graphics, etc.) needed to run the implementations.
>
> Common Example: https://retrorgb.com/mister.html

FRR (False Rejection Rate): Percentage of a biometric or authentication system incorrectly denies access to a legitimate, authorized user

FTP (File Transfer Protocol): A network protocol that transfers files between networked clients and servers without native encryption. By default, Port 21 is the default port for FTP.

FTPS (FTP Secure): An extension of FTP that secures FTP connections using TLS encryption. By default, implicit FTPS commonly uses port 990, while explicit FTPS by default commonly uses port 21.

G

GCM (Galois/Counter Mode): An efficient mode for operation for symmetric key cryptographic encryption that provides confidentiality and integrity and commonly used with AES.

GDPR: A regulation within the European Union that governs personal-data privacy, processing, and protection.

[Link](https://gdpr.eu/what-is-gdpr/)

GPG (GNU Privacy Guard): A free software implementation of OpenPGP used to encrypt, decrypt, and digitally sign information.

[Link](https://www.gnupg.org/)

GPO (Group Policy Object): A feature that centrally configures Windows users, applications and computers within Active Directory.

[Link](https://www.lenovo.com/us/en/glossary/what-is-gpo/?orgRef=https%253A%252F%252Fwww.google.com%252F&srsltid=AU7gw4Vp-hM7eGuX4GGk0Qg3apxUqUXeANT5dsJq1mKX7xUTEySDC7_a)

GPS (Global Positioning System): A free service that utilizes a satellite-based system to provide location, navigation, and precise timing. Owned by the United States government, the GPS was originally developed for military navigation and operations. However, after a Korean passenger plane was accidentally shot down after straying into restricted Soviet airspace, U.S. President Reagan announced that GPS would be made available for civilian use.

[Link](https://www.gps.gov/)

GPU (Graphics Processing Unit): A processor optimized for parallel calculations, graphics rendering, and accelerated computing.

GRE (Generic Routing Encapsulation): A tunneling protocol developed by Cisco Systems that can encapsulate a wide variety of network-layer protocols without providing encryption.

H

HA (High Availability): A design approach that keeps a system running despite failures by minimizing downtime through redundancy and fault tolerance.

HDD (Hard Disk Drive): A magnetic data storage device that uses spinning platters coated with magnetic material to store digital data. The data is retained in a non-volatile manner (meaning it stays saved even when the computer is turned off).

HIDS (Host-Based Intrusion Detection System): A system that monitors an OS host for suspicious activity and unauthorized changes. HIDS is installed on individual devices connected to the internet or an organization's internal network and detects malicious activity e.g. threats coming from inside the organization. It can also identify infected devices that may spread malware to other systems.

> Example:
>
> https://www.ossec.net/ossec-development-timeline/

HIPS (Host-Based Intrusion Prevention System): A software package that detects and blocks suspicious activity occurring on an individual endpoint.

HMAC (Hashed Message Authentication Code): A type of message authentication code that verifies message integrity for blocks that were sent and authenticity using a secret key and hash function (such as SHA-256 or MD5).

> Example: Both SSH and IPsec can use HMAC

HOTP (HMAC-based One-Time Password): A password algorithm that generates one-time passwords using HMAC and an incrementing counter.

HSM (Hardware Security Module): A physical tamper-resistant device that generates, protects, and uses cryptographic keys.

HTML: The standard markup language that structures content displayed by web browsers.

HTTP: An application protocol that transfers web resources between clients and servers. By default, Port 80 is for HTTP.

HTTPS: An extension of HTTP that's protected by TLS for encrypted, authenticated web communication. By default, Port 443 is for HTTPS.

HVAC: Technology systems that control indoor heating, cooling, ventilation, and air quality.

I

IaaS (Infrastructure as a Service): A cloud model that provides virtualized computing, storage, and networking resources.

IaC (Infrastructure as Code): The process of provisioning and managing infrastructure through version-controlled configuration files rather than manual processes or interactive interfaces.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-infrastructure-as-code-iac-security)

IAM (Identity and Access Management): A framework for managing digital identities, authentication, authorization, policies and access lifecycles.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-identity-access-management-iam)

ICMP (Internet Control Message Protocol): A network protocol that reports network errors (e.g. Destination Unreachable or Time Exceeded Pings) and operational status between IP devices. It works along IP to help devices and network equipment identify problems with data delivery. A ping command uses ICMP.

ICS (Industrial Control Systems): A broad umbrella term for computer systems that control, monitor and automate the hard and software of industrial equipment, such as factory machinery and power plants. ICS is the general category that includes SCADA, controllers, sensors, communication networks, and industrial equipment. They are prime targets for nation-state adversaries.

> Example:
>
> A water tank has a sensor that measures the water level. The ICS monitors and controls the pump, while the ICS uses SCADA to display the water level and pump status on the operator's screen. If configured and permitted, the operator can use SCADA to start or stop the pump remotely.

[Link](https://www.cisa.gov/topics/industrial-control-systems)

IDEA (International Data Encryption Algorithm): A symmetric key block cipher using a 128-bit key.

IDF (Intermediate Distribution Frame): A cable rack/telecommunications room that connects horizontal cabling from end-user devices to the MDF (main distribution frame).

IdP (Identity Provider): A service that authenticates users and confirms it to other services.

IDS (Intrusion Detection System): A device or software that monitors systems or network traffic to alert suspicious activity or possible intrusions. HIDS & WIDS are a common type of IDS.

IEEE (Institute of Electrical and Electronics Engineers): A professional organization that develops widely adopted technical standards.

[Link](https://www.ieee.org/)

IKE (Internet Key Exchange): A protocol that negotiates IPsec security associations and cryptographic keys.

IM (Instant Messaging): A type of online chat that enables real-time text communication between users over networks. E.G. AOL Instant Messenger

IMAP (Internet Message Access Protocol): A common Internet protocol that stores emails on a remote server without downloading them to a client, which allows users to access and sync the same messages across multiple devices. Emails remain on the server until deleted by the user.

By default, IMAP uses Port 143 for unencrypted (plaintext) connections (can be upgraded to a secure session using the STARTTLS command) and Port 993 for encrypted connections over SSL/TLS.

IoC (Indicator of Compromise): Actual evidence suggesting that a system or network may have been breached, such as a malicious IP address, or unusual activity (e.g. an unauthorized login attempt).

> Example:
>
> If an attacker uses a stolen password to access an email account without permission, the security team can confirm the unauthorized login through logs showing the attacker's IP address and login activity. These logs provide evidence of the compromise, while specific details, such as a malicious IP address, can serve as IoCs.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-are-indicators-of-compromise-ioc)

IoT (Internet of Things): A physical device (e.g., an appliance) embedded with software, electronics, and network connectivity to collect, exchange, or act upon data.

IP (Internet Protocol): Addresses and routes packets across interconnected networks.

[Link](https://www.geeksforgeeks.org/computer-networks/what-is-internet-protocol-ip/)

IPS (Intrusion Prevention System): A technology that detects and automatically blocks malicious network or system activity. Example: HIPS.

IPsec (Internet Protocol Security): A secure network protocol suite that authenticates and encrypts IP network traffic e.g. VPN.

IR (Incident Response): An approach that defines roles and responsibilities and includes the steps needed to properly resolve, document, and communicate about an incident during/after it has occurred.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-incident-response)

[Link](https://www.comptia.org/en/blog/what-is-an-incident-response-plan-and-how-to-create-one/)

IRC (Internet Relay Chat): An application layer protocol that supports real-time text conversations through channels or direct messages.

IRP (Incident Response Plan): A plan that documents instructions for preparing, detecting, responding to, and recovering from incidents.

ISO: An international organization creating voluntary standards across industries and technologies.

ISP (Internet Service Provider): A company that provides customers internet connectivity and related services.

ISSO: An individual maintaining an information system's operational security posture and compliance.

IV (Initialization Vector): A fixed, non-secret value used in encryption to ensure that the same data produces different encrypted results each time.

J

No J terms were included in the supplied material.

K

KDC (Key Distribution Center): A trusted server that issues session keys for secure communications.

KEK (Key Encryption Key): A cryptographic key used to encrypt and protect other keys.

L

L2TP (Layer 2 Tunneling Protocol): A tunneling protocol used to create secure VPN connections, but it requires pairing with another protocol for encryption (e.g. IPsec).

LAN (Local Area Network): A network that connects devices across a limited geographic area. E.G. LAN Party

LDAP (Lightweight Directory Access Protocol): A protocol for accessing, querying and managing distributed directory information over an IP network. By default, Port 389 is the default port for LDAP to use for directory services, like user authentication.

LEAP (Lightweight Extensible Authentication Protocol): A legacy and proprietary Cisco wireless authentication protocol that authenticates users through their credentials to grant them network access. It relies on a modified version of MS-CHAP and it is vulnerable to offline dictionary password attacks. It has well known security weaknesses and should be replaced with newer, secure methods such as EAP-TLS and PEAP to overcome LEAP's restrictions.

> Link:
> https://securew2.com/blog/leap-authentication-and-how-it-works

M

MaaS (Monitoring as a Service): A cloud service that remotely observes a companies infrastructure, applications, servers and services. Not to be confused with Model as a Service.

MAC (Mandatory Access Control): An access control model where access is determined by centrally enforced security policies (e.g. opera□ng system constrains), often using classifications, security labels and user clearances.

Example: A user without the required clearance cannot access a classified document, even if its owner wants to share it.

MAC (Media Access Control): A unique hardware identifier used for local network interface communication (e.g. a Wi-Fi adapter can use MAC).

MAC (Message Authentication Code): A cryptographic value that verifies message authenticity and integrity.

MAN (Metropolitan Area Network): A network that connects networks (LANS) across a city or metropolitan region.

MBR (Master Boot Record): Legacy disk sector containing boot code and partition information.

MD5: Broken 128-bit hashing algorithm vulnerable to collision attacks.

MDF (Main Distribution Frame): Central telecommunications point connecting external services and internal cabling.

MDM (Mobile Device Management): Centrally configures, monitors, and secures organizational mobile devices.

MFA (Multifactor Authentication): Requires two or more different authentication factor types.

MFD (Multifunction Device): Office equipme nt combining several functions within one device.

MFP (Multifunction Printer): Printer combining capabilities such as scanning, copying, and faxing.

ML (Machine Learning): AI method enabling systems to learn patterns and make predictions from data.

MMS (Multimedia Messaging Service): Sends multimedia messages across cellular networks.

MOA (Memorandum of Agreement): Formal document defining cooperative responsibilities toward a shared objective.

MOU (Memorandum of Understanding): Document describing mutual intentions between parties, often without contractual commitment.

MPLS: Forwards network traffic using labels for efficient, predictable routing.

MSA (Master Service Agreement): Establishes recurring terms governing future transactions between parties.

MSCHAP: Microsoft challenge-response authentication protocol derived from CHAP.

MSP (Managed Service Provider): Third party remotely managing customer technology under a service agreement.

MSSP (Managed Security Service Provider): Third party delivering outsourced security monitoring and management.

MTBF (Mean Time Between Failures): Average operational time between repairable equipment failures.

MTTF (Mean Time to Failure): Average operating time before a nonrepairable component fails.

MTTR (Mean Time to Recover): Average time required to restore service after failure.

MTU (Maximum Transmission Unit): Largest packet size a network interface can transmit without fragmentation.

N

NAC (Network Access Control): A process that evaluates devices and restricts unauthorized devices. It enforces policy before or during network access.

NAT (Network Address Translation): Rewrites IP addresses as traffic passes through a network device.

NDA (Non-Disclosure Agreement): Contract requiring parties to protect specified confidential information.

NFC (Near-Field Communication): Enables short-range wireless communication between nearby compatible devices.

NGFW (Next-Generation Firewall): Combines traditional filtering with application awareness and advanced threat prevention.

NIDS (Network-Based Intrusion Detection System): Monitors network traffic and alerts on suspicious activity.

NIPS (Network-Based Intrusion Prevention System): Inspects network traffic and automatically blocks detected threats.

NIST: U.S. agency developing measurement standards and cybersecurity guidance.

NTFS: Microsoft file system supporting permissions, journaling, encryption, and large volumes.

NTLM: Legacy Microsoft authentication protocols using challenge-response mechanisms.

NTP (Network Time Protocol): Synchronizes clocks among networked computer systems. By default, Port 123 is used for NTP.

O

OAuth (Open Authorization): Open standard letting applications access user information without receiving the user's password.

OCSP (Online Certificate Status Protocol): Internet protocol for checking an X.509 digital certificate's revocation status.

OID (Object Identifier): Globally unique identifier used to name an object or defined set of data.

OS (Operating System): Software managing computer hardware, resources, applications, and common program services.

OSINT (Open-Source Intelligence): Intelligence collected and analyzed from publicly available sources.

OSPF (Open Shortest Path First): Link-state routing protocol used to exchange routes within an IP network.

OT (Operational Technology): Hardware and software monitoring or controlling physical devices, processes, and enterprise events.

OTA (Over the Air): Wireless transmission of data, configurations, or software updates to devices.

OVAL (Open Vulnerability Assessment Language): Community standard for publicly sharing machine-readable security assessment content.

P

P12 (PKCS #12): Portable format storing or transporting private keys, certificates, and related secrets.

P2P (Peer to Peer): Decentralized model where equal participants can each initiate communication and share resources.

PaaS (Platform as a Service): Cloud platform for developing, running, and managing applications without maintaining underlying infrastructure.

PAC (Proxy Auto Configuration): Method enabling web browsers to select an appropriate proxy server automatically.

PAM (Privileged Access Management): Controls and monitors privileged access to critical systems and assets.

PAM (Pluggable Authentication Modules): Framework integrating multiple authentication methods through a common application interface.

PAP (Password Authentication Protocol): Simple authentication protocol transmitting usernames and passwords in plaintext.

PAT (Port Address Translation): Translates TCP or UDP connections between private hosts and public networks using port numbers.

PBKDF2 (Password-Based Key Derivation Function 2): PKCS #5 key derivation function strengthening passwords through salting and repeated computation.

PBX (Private Branch Exchange): Private telephone network serving users within a company or organization.

PCAP (Packet Capture): Process or file containing data packets captured from a network segment.

PCI DSS (Payment Card Industry Data Security Standard): Security requirements for organizations handling payment-card information.

PDU (Power Distribution Unit): Device distributing electrical power to multiple computers or network components, especially in racks.

PEAP (Protected Extensible Authentication Protocol): An extension(?) of EAP that protects authentication exchanges, including passwords, within an encrypted tunnel.

PED (Personal Electronic Device): Small electronic device used for personal communication, data management, or recreation.

PEM (Privacy Enhanced Mail): Text-based format commonly used to store certificates and cryptographic keys.

PFS (Perfect Forward Secrecy): Ensures compromised long-term keys cannot decrypt previously recorded sessions.

PGP (Pretty Good Privacy): Program providing encryption, digital signatures, privacy, and authentication for data communications.

PHI (Personal Health Information): Individually linked information about health status, healthcare delivery, or healthcare payment.

PII (Personally Identifiable Information): Information usable alone or with other data to identify, contact, or locate someone.

PIV (Personal Identity Verification): U.S. federal standard for reliable identification and access-control credentials.

PKCS (Public Key Cryptography Standards): RSA-established standards covering public-key cryptography formats and operations.

PKI (Public Key Infrastructure): Roles, policies, technologies, and procedures managing digital certificates and public-key encryption.

ELI5: The main purpose of PKI is to manage digital certificates to secure communications and verify identities.

POP (Post Office Protocol): An older Internet protocol that lets local email clients (e.g. Outlook) retrieve/download messages from remote servers. By default, Port 110 is the standard default port for unencrypted POP3.

For example:

1. Someone sends you an email.
2. The email is stored on your mail server.
3. Your email application uses **POP3** to download the email to your computer.

[Link](https://support.microsoft.com/en-us/outlook/what-is-the-difference-between-pop-and-imap)

POTS (Plain Old Telephone Service): Traditional voice-grade residential and small-business telephone service.

PPP (Point-to-Point Protocol): Data-link protocol establishing direct connections between two network nodes.

PPTP (Point-to-Point Tunneling Protocol): Legacy protocol for creating virtual private network tunnels.

PSK (Pre-Shared Key): Secret exchanged securely beforehand and later used for authentication or encryption.

PTZ (Pan-Tilt-Zoom): Camera supporting remote directional movement and zoom control.

PUP (Potentially Unwanted Program): Software a user may consider undesirable despite possibly consenting to installation.

R

RA (Recovery Agent): Entity authorized to recover cryptographic keys, certificates, or encrypted data.

RA (Registration Authority): Verifies certificate requests and authorizes a Certificate Authority to issue certificates.

RACE (Research and Development in Advanced Communications Technologies in Europe): Former European program researching advanced telecommunications networks.

RAD (Rapid Application Development): Software methodology prioritizing rapid prototypes, user feedback, and iterative releases.

RADIUS (Remote Authentication Dial-In User Service): A protocol used for controlling, logging and centralizing network AAA (Authentication, Authorization, and Accounting). By default, Port 1812/1813 is used for RADIUS.

RAID (Redundant Array of Inexpensive Disks): Combines drives into one logical unit for redundancy or improved performance.

RAS (Remote Access Server): Server providing remote users or computers access to network resources.

RAT (Remote Access Trojan): Malware providing attackers a backdoor for remote administrative control.

RBAC (Role-Based Access Control): An access control model that restricts system access according to authorized users' organizational roles.

> Example:
>
> An HR employee can access personnel records because their role grants that permission.

RBAC (Rule-Based Access Control): A type of an access control model that grants or denies access according to predefined rules, conditions, and contextual policies.

> Example:
>
> A rule might block all access to a server room outside of normal 9:00 AM to 5:00 PM working hours, even for IT staff

RC4 (Rivest Cipher Version 4): Fast stream cipher now considered insecure because of serious vulnerabilities.

RDP (Remote Desktop Protocol): Microsoft protocol providing graphical remote access to another networked computer. By default, Port 3389 is used for RDP.

RFID (Radio Frequency Identifier): Technology using electromagnetic fields to identify and track tags attached to objects.

RIPEMD (RACE Integrity Primitives Evaluation Message Digest): Family of cryptographic hash functions developed in Belgium.

ROI (Return on Investment): Measure comparing an investment's financial benefit with its cost.

RPO (Recovery Point Objective): Maximum acceptable data loss measured backward in time from disruption.

RSA (Rivest, Shamir, and Adleman): Public-key cryptosystem widely used for encryption, key exchange, and digital signatures.

RTBH (Remotely Triggered Black Hole): Routing technique discarding malicious traffic to mitigate denial-of-service attacks.

RTO (Recovery Time Objective): Targeted maximum duration for restoring a business process after disruption.

RTOS (Real-Time Operating System): Operating system processing time-sensitive data with predictable, minimal delays.

RTP (Real-Time Transport Protocol): Network protocol delivering audio and video across IP networks.

S

S/MIME (Secure/Multipurpose Internet Mail Extensions): Standard providing public-key encryption and digital signatures for MIME email.

SaaS (Software as a Service): Provider-hosted applications delivered to customers over the internet.

SAE (Simultaneous Authentication of Equals): Password-authenticated key exchange protocol used by WPA3 wireless networks.

SAML (Security Assertions Markup Language): Standard exchanging authentication and authorization data between identity (IdP) and service providers.

SAN (Storage Area Network): Dedicated network providing consolidated block-level storage access.

SAN (Subject Alternative Name): X.509 extension listing additional hostnames or identities protected by one certificate.

SASE (Secure Access Service Edge): Architecture combining wide-area networking with cloud-delivered security functions.

SCADA (Supervisory Control and Data Acquisition): A subset of ICS, Architecture monitoring and controlling industrial processes through computers and networked communications.

SCAP (Security Content Automation Protocol): Standards enabling automated vulnerability management, measurement, and policy-compliance evaluation.

SCEP (Simple Certificate Enrollment Protocol): Protocol automating secure digital-certificate enrollment and issuance.

SD-WAN (Software-Defined Wide Area Network): Software-controlled WAN that optimizes traffic routing across remote locations.

SDK (Software Development Kit): Packaged collection of tools and resources for developing software.

SDLC (Software Development Lifecycle): Process for planning, creating, testing, deploying, and maintaining information systems.

SDLM (Software Development Lifecycle Methodology): Framework defining software-development stages from feasibility through maintenance.

SDN (Software-Defined Networking): Uses software controllers or APIs to direct network traffic and manage hardware.

SE Linux (Security-Enhanced Linux): Linux security framework enforcing mandatory access-control policies.

SED (Self-Encrypting Drives): Storage drives automatically and continuously encrypting stored data without user interaction.

SEH (Structured Exception Handler): Windows mechanism handling hardware and software exceptions.

SFTP (Secured File Transfer Protocol): Secure file-transfer method using SSH to encrypt network data.

SHA (Secure Hashing Algorithm): NIST-published family of cryptographic functions producing fixed-length message digests.

SHTTP (Secure Hypertext Transfer Protocol): Obsolete alternative to HTTPS for encrypting HTTP web communications.

SIEM (Security Information and Event Management): A software that monitors and analyzes security events and alerts from applications and network hardware.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-siem)

SIM (Subscriber Identity Module): Smart card securely storing information identifying a mobile-service subscriber.

SLA (Service-Level Agreement): Provider-client commitment defining service quality, availability, responsibilities, and performance expectations.

SLE (Single Loss Expectancy): Expected monetary loss from one occurrence of a risk affecting an asset.

SMS (Short Message Service): Text-messaging service used by telephone, internet, and mobile-device systems.

SMTP (Simple Mail Transfer Protocol): An internet standard transmitting email across IP networks. By default, Port 25 is used for SMTP.

SMTPS (Simple Mail Transfer Protocol Secure): Secures SMTP using TLS for authentication, integrity, and confidentiality.

SNMP (Simple Network Management Protocol): Collects, organizes, and modifies information about managed IP network devices. By default, Port 161/162 is used for SNMP.

SOAP (Simple Object Access Protocol): Messaging specification for exchanging structured information between web services.

SOAR (Security Orchestration, Automation, and Response): A collection of software tools and solutions that connect security systems via APIs and automate incident response with standardized playbooks, and provide centralized case management to help SOC (Security Operations Center) analysts investigate and remediate threats faster.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-soar)

Scenario:

1. SOAR is proactively configured to receive an alert through an integration, API, or event mechanism.
2. Sometime later, an email security tool detects a suspicious phishing email and sends an alert to the SOAR platform.
3. **Upon receiving the alert, SOAR** triggers the predefined workflow. SOAR queries the SIEM, threat intelligence tools, and email security systems to gather relevant information, assess the threat, and determine the appropriate response actions from a **playbook containing a** predefined set of instructions or rules. The playbook tells the system what steps to perform (e.g., quarantine the email, block malicious indicators, and initiate account-protection actions).
4. SOAR records the incident, evidence, actions taken, and results for the SOC analyst to review.

SoC (System on Chip): Integrated circuit combining major computer or electronic-system components on one chip.

SOC (Security Operations Center): Centralized team monitoring and addressing organizational and technical security issues.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-a-security-operations-center-soc)

SOW (Statement of Work): Project document defining vendor activities, deliverables, responsibilities, and timelines.

SPF (Sender Policy Framework): Email authentication method detecting forged sender addresses during delivery.

SPIM (Spam over Internet Messaging): Unsolicited messages distributed through instant-messaging systems.

SQL (Structured Query Language): Language designed to create, query, and manage relational database data.

SQLi (SQL Injection): Attack inserting malicious SQL statements into application inputs for execution.

SRTP (Secure Real-Time Protocol): Protects RTP traffic with encryption, authentication, integrity, and replay prevention.

SSD (Solid State Drive): Fast storage device using nonvolatile flash memory instead of mechanical disks.

SSH (Secure Shell): Cryptographic protocol securely operating network services across unsecured networks. By default, SSH uses Port 22. The designer chose 22 because it was available and sat perfectly between the two insecure protocols he designed SSH to replace: FTP (port 21) and Telnet (port 23)

SSL (Secure Sockets Layer): Legacy technology creating encrypted links between web servers and browsers.

SSO (Single Sign-On): Lets users access multiple related systems after one authentication.

STIX (Structured Threat Information eXchange): Language and serialization format for exchanging cyber-threat intelligence.

SWG (Secure Web Gateway): Filters malicious web traffic and enforces organizational or regulatory browsing policies.

T

TACACS+ (Terminal Access Controller Access Control System): Centralizes validation of users accessing routers or network-access servers.

TAXII (Trusted Automated eXchange of Indicator Information): Application-layer protocol for simple, scalable cyber-threat information exchange.

TCP/IP (Transmission Control Protocol/Internet Protocol): Communications protocol suite interconnecting devices across networks and the internet.

TGT (Ticket Granting Ticket): Kerberos credential used to request service tickets without resubmitting user credentials.

TKIP (Temporal Key Integrity Protocol): Legacy IEEE 802.11 wireless security protocol introduced to improve WEP.

TLS (Transport Layer Security): Cryptographic protocol protecting communications across computer networks.

TOC (Time-of-Check): Moment a system verifies a resource's state before later use.

TOTP (Time-Based One-Time Password): Algorithm generating temporary passwords valid for short time periods.

TOU (Time-of-Use): Moment a previously checked resource is accessed, when its state may have changed.

TPM (Trusted Platform Module): Endpoint security chip storing cryptographic keys and supporting hardware authentication.

TTP (Tactics, Techniques, and Procedures): Describes attackers' strategic goals, methods, and operational steps.

TSIG (Transaction Signature): Shared-secret protocol authenticating DNS messages and updates.

U

UAT (User Acceptance Testing): The final software testing phase where users verify that the software handles required real-world tasks.

UAV (Unmanned Aerial Vehicle): A type of aircraft that operates without a human pilot a.k.a. a drone.

UDP (User Datagram Protocol): A connectionless protocol that exchanges time-sensitive messages without guaranteed delivery or ordering. It's used for time-sensitive transmissions where minor data loss is acceptable in exchange for speed, e.g. VoIP (Voice over IP), online gaming and DNS lookups.

[Link](https://www.lenovo.com/us/en/glossary/what-is-udp)

UEFI (Unified Extensible Firmware Interface): A modern firmware interface designed to replace BIOS; it connects computer hardware to the operating system.

UEM (Unified Endpoint Management): Software that enables IT and security teams to manage, monitor, and secure all organizational devices (e.g., mobile devices, desktops, and other endpoints) through a single tool, regardless of operating system or location. UEM combines mobile management tools (e.g. MDM) with solutions for managing on-premises and remote PCs.

[Link](https://www.ibm.com/think/topics/uem)

UPS (Uninterruptible Power Supply): A battery backup device that provides temporary power when the primary source fails.

URI (Uniform Resource Identifier): A unique character string that identifies a name or resource on the internet.

URL (Uniform Resource Locator): A type of URI that points to a resource on a computer network and provides the mechanism (such as http, https, or ftp) to retrieve it.

[Link](https://en.wikipedia.org/wiki/URL)

USB (Universal Serial Bus): A standard for digital data transmission and power delivery between many types of electronics.

[Link](https://en.wikipedia.org/wiki/USB)

USB OTG (USB On-The-Go): A standard that allows compatible mobile devices to act as USB host and connect directly to other devices without a computer.

UTM (Unified Threat Management): A single security product that combines multiple functions (traditionally provided by separate tools) into one system.

UTP (Unshielded Twisted Pair): A common type of copper cable that uses twisted wire pairs for network communications.

V

VBA (Visual Basic for Applications): A Microsoft event-driven programming language embedded within applications for automation. For example, macros in Microsoft Office applications are created using VBA.

VDE (Virtual Desktop Environment): A virtual machine that provides a graphical experience similar to a physical desktop.

VDI (Virtual Desktop Infrastructure): The technology that hosts desktop operating systems centrally on a server and delivers them to users remotely.

[Link](https://azure.microsoft.com/en-us/resources/cloud-computing-dictionary/what-is-virtual-desktop-infrastructure-vdi)

VLAN (Virtual Local Area Network): A group of devices across LAN segments to communicate as one network.

VLSM (Variable Length Subnet Masking): A technique that divides an IP address space into differently sized subnets rather than uniform, equal sizes.

VM (Virtual Machine): An emulated computer system that provides functionality comparable to physical hardware.

VoIP (Voice over Internet Protocol): Technologies that deliver voice and multimedia communications across IP networks.

VPC (Virtual Private Cloud): A secure, isolated private-cloud environment hosted within a public cloud.

[Link](https://cloud.google.com/discover/virtual-private-cloud-vpc)

VPN (Virtual Private Network): A technology that creates an encrypted connection to secure remote access across a less secure network e.g. the internet.

VTC (Video Teleconferencing): A technology that enables people in different locations to hold face-to-face meetings remotely.

W

WAF (Web Application Firewall): A security system that operates on the application layer (Layer 7). It filters, monitors, and blocks HTTP(S) traffic to and from web services.

> Link:
> https://www.cisco.com/site/us/en/learn/topics/security/what-is-web-application-firewall-waf.html

WAP (Wireless Access Point): A networking device that connects Wi-Fi clients to a wired network.

WEP (Wired Equivalent Privacy): An obsolete wireless-network security protocol that is now considered insecure.

WIDS (Wireless Intrusion Detection System): A type of IDS system that detects and alerts administrators to suspicious activity on wireless networks. Some examples include suspected MAC spoofing and Brute-Force Anomalies.

WIPS (Wireless Intrusion Prevention System): A type of IPS that monitors wireless networks and automatically blocks detected threats, rogue access points, and unauthorized devices.

WO (Work Order): A document that authorizes and describes maintenance, repair, installation, or other work to be completed. Examples can include WOs for electric outage, gas leakage, etc.

WPA (Wi-Fi Protected Access): A wireless security standard that improved WEP through stronger encryption and authentication.

WTLS (Wireless TLS): A legacy security protocol that provides privacy, integrity, and authentication for Wireless Application Protocol communications.

X

XDR (Extended Detection and Response): A security platform that integrates security data across endpoints, networks, email, and cloud systems to detect and respond to threats. XDR integrates with SIEM, EDR, and SOAR to strengthen cybersecurity.

[Link](https://www.microsoft.com/en-us/security/business/security-101/what-is-xdr)

XML (Extensible Markup Language): A text-based language for structuring, storing, and exchanging data using customizable tags and attributes. XML requires opening and closing tags (e.g. <item> value </item>)

[Link](https://aws.amazon.com/compare/the-difference-between-json-xml/)

XOR (Exclusive OR): A logical operation that:

- returns true when the inputs are different from each other
- returns false when the inputs match.

XSRF (Cross-Site Request Forgery): Another name for CSRF, an attack that tricks authenticated browsers into sending unauthorized requests.

XSS (Cross-Site Scripting): An attack that injects malicious scripts into trusted websites for execution in users' browsers.